Report 1 – Scansione iniziale

Vulnerability assessment e remediation sul target Metasploitable2

1. Obiettivo dell'esercizio

Studente	Squicciarino Donato
Esercizio	Esercizio finale W12D4
Corso	Epicode – Cybersecurity & Ethical Hacker
Documento	Report 1 di 3 – ScansioneInizio
Target	Metasploitable2 (192.168.51.101)
Strumento	Nessus Essentials – policy "Scansione di rete di base"

L'obiettivo dell'esercizio è valutare lo stato di sicurezza della macchina Metasploitable2 e dimostrare, con evidenze verificabili, che le vulnerabilità critiche possono essere ridotte con azioni di rimedio mirate. Il lavoro si articola in tre fasi, ciascuna documentata da un report:

1. **Scansione iniziale (questo report):** scansione completa del target, individuazione delle vulnerabilità critiche e motivazione delle scelte.
2. **Remediation (RemediationMeta):** implementazione delle azioni di rimedio su un massimo di quattro criticità, con screenshot e spiegazione dei passaggi.
3. **Scansione finale (ScansioneFine):** nuova scansione con la stessa policy e confronto con i risultati iniziali per dimostrare l'efficacia delle azioni.

2. Scansione iniziale

La scansione è stata eseguita con Nessus sul target 192.168.51.101, con policy "Scansione di rete di base" e base di gravità CVSS v3.0. È iniziata il 29 settembre alle 15:44 e si è conclusa alle 16:05 (21 minuti). Il grafico a ciambella nel pannello laterale riassume la distribuzione per gravità: le voci informative sono la maggioranza, ma sono presenti anche vulnerabilità critiche, alte, medie e basse. La schermata seguente mostra l'elenco con le criticità.

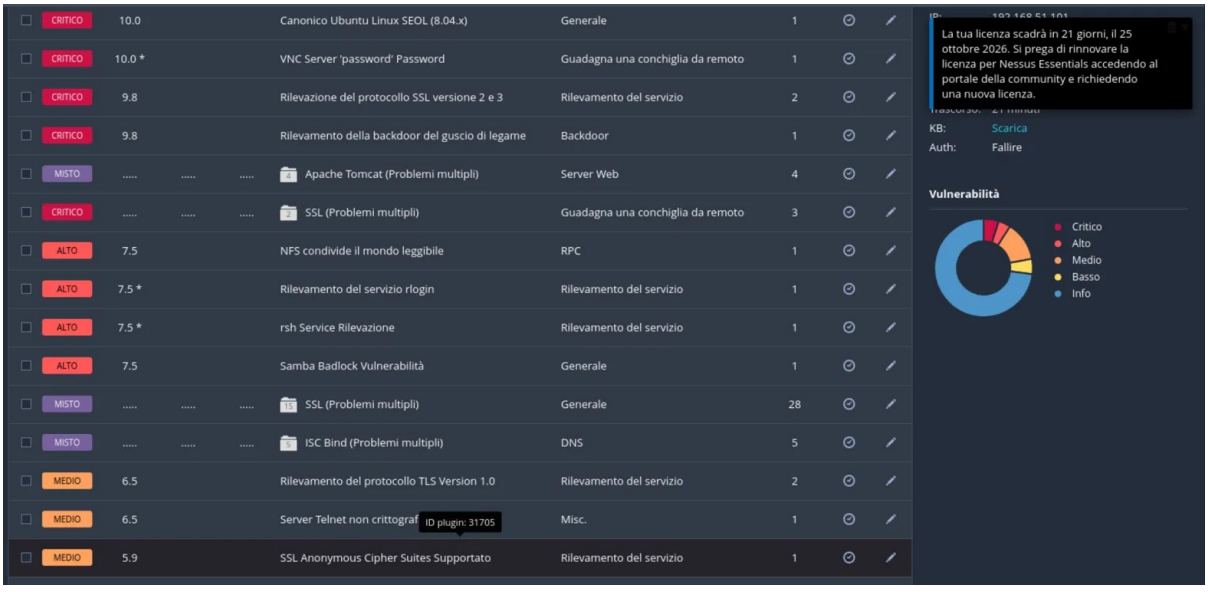


Figura 1 – Risultati della scansione iniziale su Metasploitable2

3. Criticità individuate e scelta delle vulnerabilità

La tabella elenca le vulnerabilità di gravità critica emerse dalla scansione e indica quali sono state selezionate per la fase di remediation.

#	Vulnerabilità	CVSS	Servizio / porta	Decisione
1	Canonical Ubuntu Linux SEOL (8.04.x)	10.0	Sistema operativo	Non selezionata (sistema obsoleto)
2	VNC Server 'password' Password	10.0	5900/tcp (vnc)	Selezionata
3	SSL Version 2 and 3 Protocol Detection	9.8	25/tcp (smtp), 5432/tcp (postgresql)	Selezionata
4	Bind Shell Backdoor Detection	9.8	1524/tcp (wild_shell)	Selezionata
5	Apache Tomcat AJP Request Injection (Ghostcat)	9.8	8009/tcp (ajp13)	Selezionata
6	Apache Tomcat SEOL (<= 5.5.x)	10.0	Apache Tomcat	Non selezionata (software obsoleto)
7	Debian OpenSSH/OpenSSL Random Number Generator Weakness	10.0	SSH e servizi SSL	Non selezionata (pacchetti obsoleti)

Criterio di scelta. Le quattro vulnerabilità selezionate (2, 3, 4 e 5) hanno tutte gravità critica e sono le più sfruttabili da remoto senza alcuna autenticazione: accesso remoto con password banale, shell root aperta, cifratura obsoleta e un connettore AJP esposto. Sono inoltre intervenibili in modo concreto sulla macchina del laboratorio. Le vulnerabilità 1, 6 e 7 dipendono dall'obsolescenza del sistema operativo e dei suoi pacchetti e per questo non sono state selezionate.

Vulnerabilità selezionate e porte coinvolte.

#	Vulnerabilità	Porta / servizio	CVSS	Plugin ID Nessus
2	VNC Server 'password' Password	5900/tcp (vnc)	10.0	61708
3	SSL Version 2 and 3 Protocol Detection	25/tcp (smtp) e 5432/tcp (postgresql)	9.8	20007
4	Bind Shell Backdoor Detection	1524/tcp (wild_shell)	9.8	51988
5	Apache Tomcat AJP Connector Request Injection (Ghostcat)	8009/tcp (ajp13)	9.8	134862

Perché la gravità è critica. Le vulnerabilità con punteggio 9.8 hanno vettore CVSS v3.0 AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H. In pratica sono raggiungibili dalla rete (AV:N), sfruttabili con bassa complessità (AC:L), senza privilegi (PR:N) e senza alcuna interazione dell'utente (UI:N), con impatto alto su riservatezza, integrità e disponibilità (C:H/I:H/A:H). Per la vulnerabilità VNC il vettore CVSS v2.0 (AV:N/AC:L/Au:N/C:C/I:C/A:C) porta al punteggio massimo di 10.0.

4. Analisi delle criticità: perché sono critiche

4.1 Canonical Ubuntu Linux SEOL (8.04.x)

Descrizione. Il sistema operativo è Ubuntu 8.04, una versione giunta a fine supporto (SEOL, Security End Of Life) da molti anni. Non riceve più aggiornamenti di sicurezza, quindi ogni vulnerabilità scoperta nel kernel e nei pacchetti resta aperta in modo permanente.

Perché è critica. È la causa radice di molte altre debolezze presenti sulla macchina: finché il sistema non viene aggiornato, nuove vulnerabilità non potranno essere corrette con una patch.

4.2 VNC Server 'password' Password

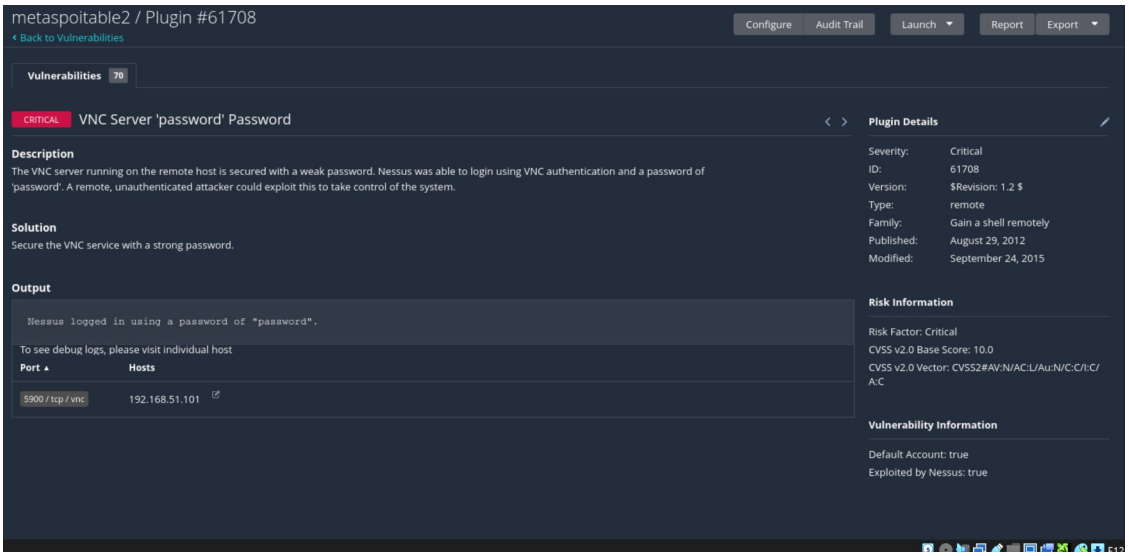


Figura 2 – Plugin 61708: Nessus ottiene l'accesso VNC con la password "password"

Descrizione. Il server VNC in ascolto sulla porta 5900/tcp è protetto da una password debole: Nessus è riuscito ad autenticarsi con "password". Il plugin segnala che si tratta di un account di default e che la vulnerabilità è stata sfruttata con successo dallo scanner.

Perché è critica. Un attaccante remoto non autenticato può indovinare la password al primo tentativo e ottenere il controllo grafico del sistema, con piena compromissione di riservatezza, integrità e disponibilità (CVSS 10.0).

4.3 SSL Version 2 and 3 Protocol Detection

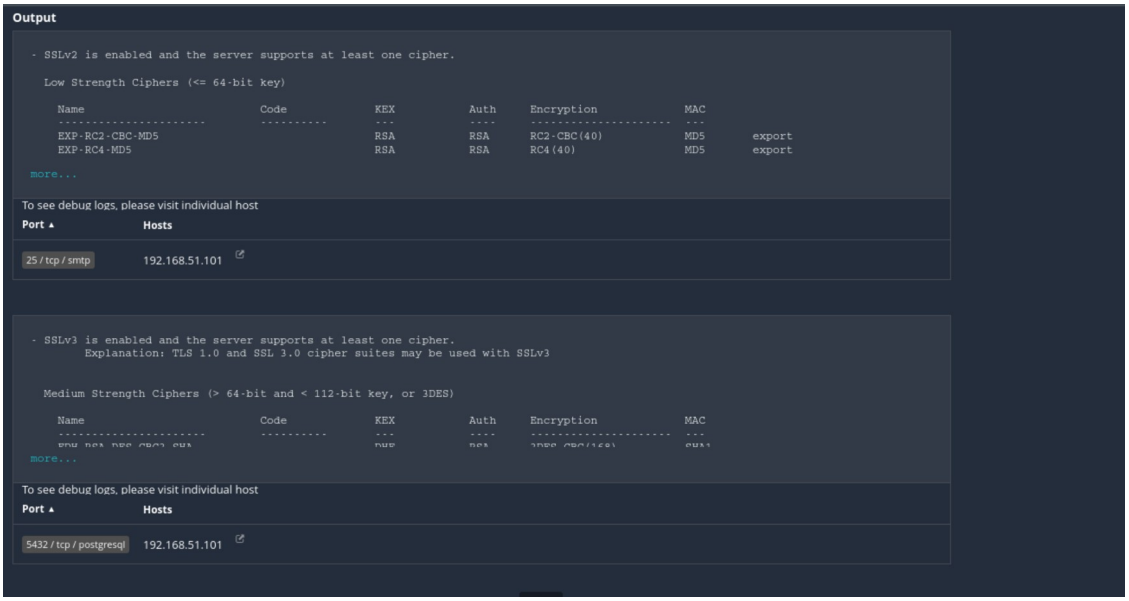


Figura 3 – Plugin 20007: SSLv2 abilitato sulla porta 25 e SSLv3 sulla porta 5432

Descrizione. Il servizio SMTP sulla porta 25/tcp accetta connessioni SSLv2 con cifrari deboli (ad esempio EXP-RC2-CBC-MD5 ed EXP-RC4-MD5, di tipo export), mentre PostgreSQL sulla porta 5432/tcp accetta SSLv3 con cifrari di forza media (3DES).

Perché è critica. SSL 2.0 e 3.0 hanno difetti crittografici noti, come lo schema di padding insicuro con cifrari CBC e la rinegoziazione di sessione non sicura. Consentono attacchi man-in-the-middle, attacchi di downgrade (ad esempio POODLE) e la decifrazione del traffico. NIST considera SSL

3.0 non più accettabile e lo standard PCI DSS non lo ritiene crittografia robusta (CVSS 9.8).

4.4 Bind Shell Backdoor Detection

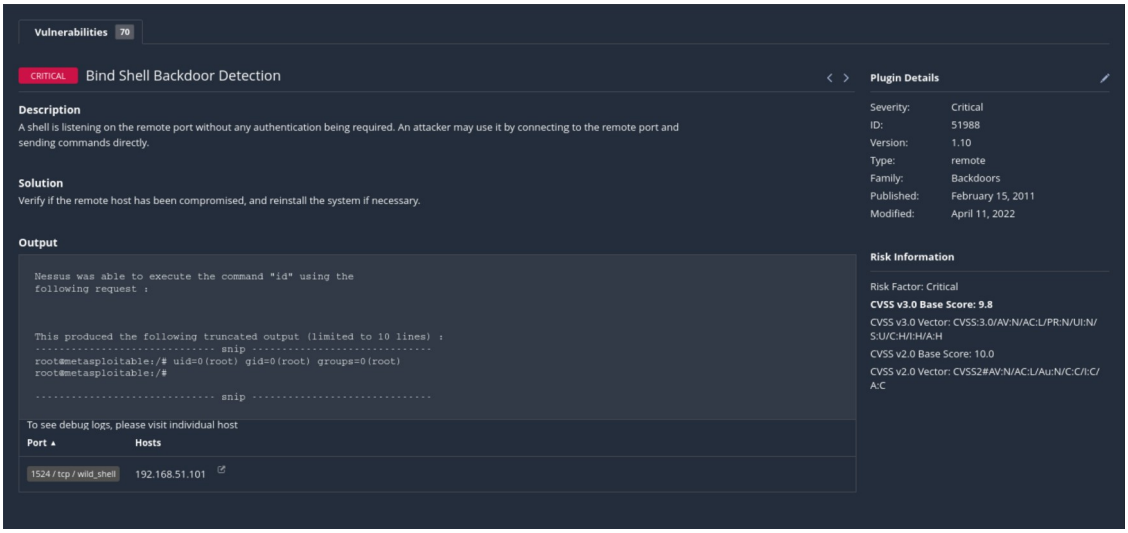


Figura 4 – Plugin 51988: shell root in ascolto sulla porta 1524/tcp

Descrizione. Sulla porta 1524/tcp è in ascolto una shell che non richiede alcuna autenticazione. Nessus ha eseguito il comando "id" e ha ottenuto uid=0(root), cioè privilegi di amministratore.

Perché è critica. Chiunque possa raggiungere la porta ottiene una shell root e può leggere, modificare o cancellare qualsiasi dato, installare malware e muoversi verso altri sistemi. È la forma più diretta di compromissione totale (CVSS 9.8).

4.5 Apache Tomcat AJP Connector Request Injection (Ghostcat)

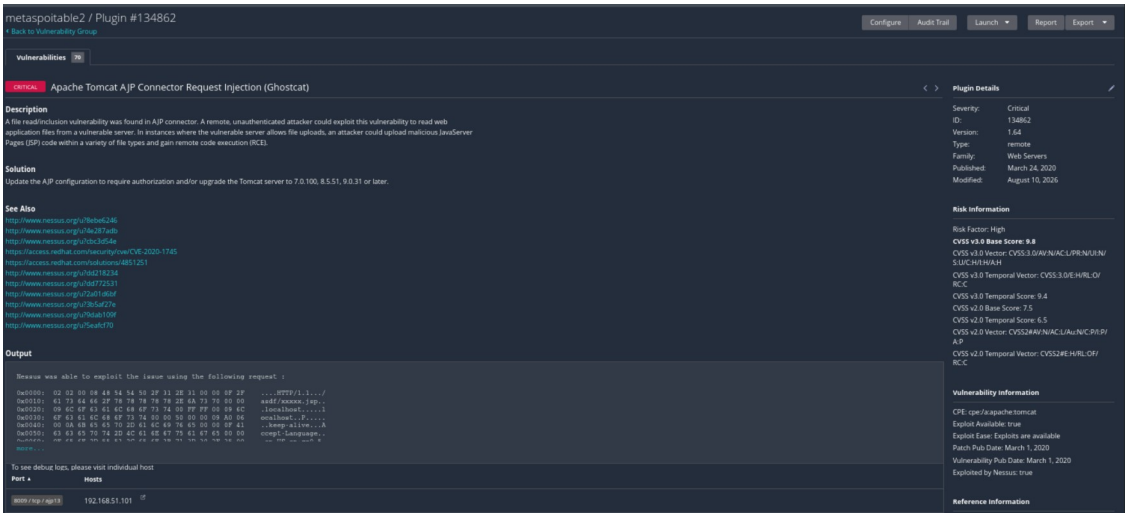


Figura 5 – Plugin 134862: Nessus sfrutta la vulnerabilità sul connettore AJP (porta 8009/tcp)

Descrizione. Il connettore AJP (Apache JServ Protocol) di Apache Tomcat è in ascolto sulla porta 8009/tcp (ajp13) ed è raggiungibile dalla rete. Si tratta della vulnerabilità nota come Ghostcat (CVE-2020-1938), una falla di lettura e inclusione di file nel connettore AJP. Il plugin segnala che esistono exploit pubblici e che Nessus è riuscito a sfruttare il problema con una richiesta AJP appositamente costruita.

Perché è critica. Un attaccante remoto non autenticato può leggere i file delle applicazioni web ospitate dal server, come file di configurazione e codice sorgente, che spesso contengono credenziali. Se il server consente il caricamento di file, può anche inserire codice JSP malevolo e ottenere l'esecuzione di codice da remoto (RCE), con compromissione completa del server (CVSS 9.8). Il fatto che esistano exploit pubblici rende lo sfruttamento alla portata anche di attaccanti poco esperti.

4.6 Vulnerabilità critiche non selezionate

Le altre criticità in tabella derivano dall'obsolescenza dei componenti, e sono comunque gravi. Apache Tomcat <= 5.5.x non è più supportato e quindi non riceve patch di sicurezza, come per il sistema operativo. Il difetto del generatore di numeri casuali di Debian OpenSSH/OpenSSL rende prevedibili le chiavi crittografiche generate: un attaccante può ricavare le chiavi private e decifrare il traffico o impersonare il server (CVSS 10.0).

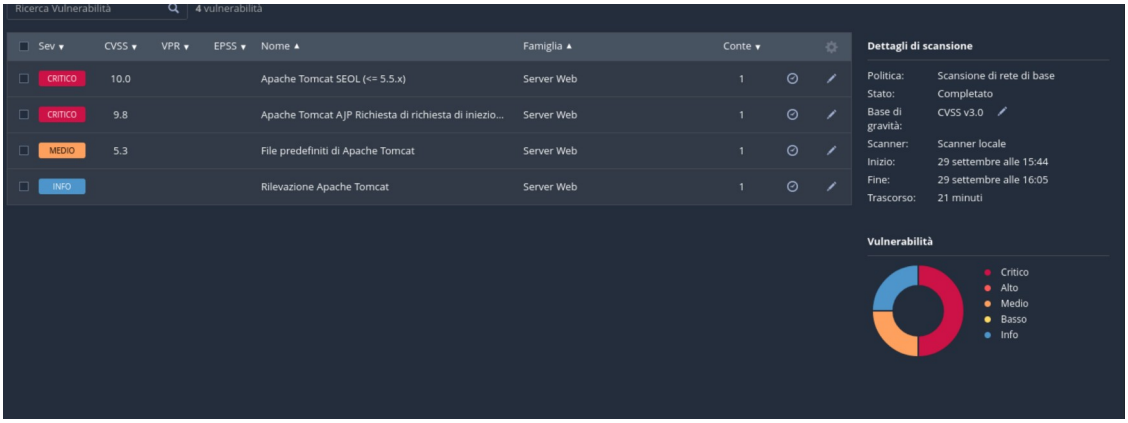


Figura 6 – Vulnerabilità Apache Tomcat rilevate dalla scansione, tra cui Tomcat SEOL (CVSS 10.0)

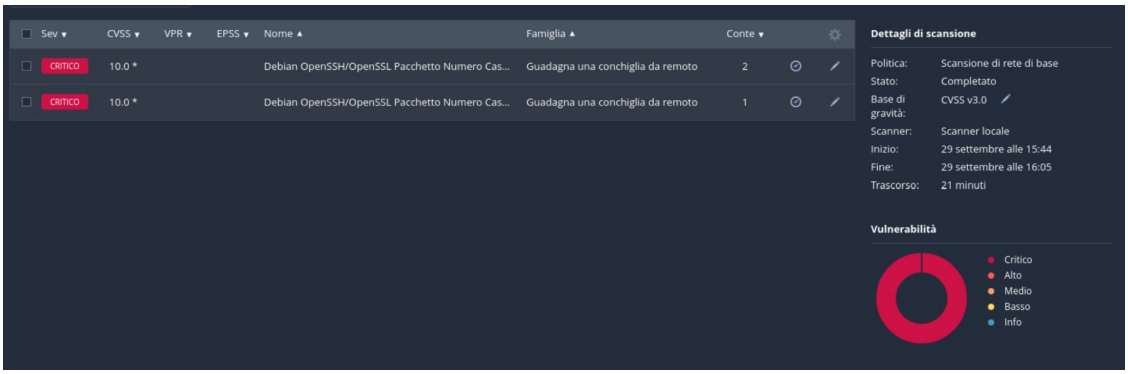


Figura 7 – Vulnerabilità critiche Debian OpenSSH/OpenSSL rilevate dalla scansione

5. Conclusioni e prossimi passi

La scansione iniziale conferma che Metasploitable2 espone più vulnerabilità critiche, sfruttabili da remoto senza autenticazione e con impatto massimo su riservatezza, integrità e disponibilità. Per la fase di remediation sono state selezionate quattro criticità: VNC con password debole, SSL 2/3, bind shell backdoor e Ghostcat sul connettore AJP. Le azioni di rimedio, con screenshot e spiegazione dei passaggi, saranno documentate nel secondo report (RemediationMeta). Il terzo report (ScansioneFine) mostrerà la scansione eseguita dopo le modifiche, con il confronto rispetto ai risultati di questo documento.